

TEMPLATE: REPORTE EJECUTIVO GQM+PRAGMATIC PARA JUNTA

Presentación Profesional de Indicadores EPSS con Trazabilidad

Versión: 1.0

Fecha: Enero 2026

Clasificación: Confidencial - Gobierno Corporativo

PORTADA

EVALUACIÓN INTEGRAL DE MÉTRICAS CIBERSEGURIDAD Framework GQM+ PRAGMATIC + EPSS 2026

Organización: [NOMBRE]

Evaluación: Enero 2026

Próxima: Enero 2027

Preparado por: [CISO/Consultor]

Revisado por: [Auditor]

Aprobado por: [CEO]

SECCIÓN 1: RESUMEN EJECUTIVO (1 página)

Mensaje Clave

POSICIÓN ACTUAL:

La evaluación GQM+PRAGMATIC revela un programa de ciberseguridad con métricas de calidad PROMEDIO de 7.5/10 (Buena), indicando que:

- ✓ Objetivos estratégicos están BIEN DEFINIDOS (trazabilidad GQM clara)
- ✓ Métricas son MAYORMENTE PRÁCTICAS (scores PRAGMATIC 7.0-8.7/10)
- ✓ Existe ALINEACIÓN REGULATORIA a NIS2, GDPR, ENS (documentado)
- ✗ OPORTUNIDAD: Mejorar precisión operativa de algunas métricas

IMPLICACIÓN PARA NEGOCIO:

La capacidad de medir y actuar sobre riesgos es proporcional a la calidad de las métricas (Framework GQM+PRAGMATIC). Puntuación actual (7.5/10) = capacidad de decisión "Buena, pero con riesgos de error".

RECOMENDACIÓN:

Invertir €115K en mejorar precisión operativa y herramientas, generando ROSI de 430% anual (€495K de valor).

Tabla Resumen: Métricas y Scores

Métrica	Actual	PRAGMATIC	GQM	Regulación	Estado
A1: Cobertura EPSS	72%	8.7/10	✓ Excelente	NIS2	✓✓
A2: MTTR Críticas	14 días	7.6/10	✓ Buena	NIS2/GDPR	⚠
A3: Efficiency EPSS	52%	7.9/10	✓ Buena	NIS2	✓
B1: MTTD	26h	7.5/10	✓ Buena	GDPR/ENS	⚠
C1: MTTE	20h	7.7/10	✓ Buena	NIS2/GDPR	⚠
D1: Phishing Click	22%	8.1/10	✓ Buena	NIS2	✓
E1: Documentación	85%	7.8/10	✓ Buena	Auditoría	✓
IGM GLOBAL	N/A	7.8/10	Excelente	Auditable	✓ BUENA

SECCIÓN 2: ANÁLISIS GQM - TRAZABILIDAD (2 páginas)

Jerarquía de Objetivos → Métricas

NIVEL 1: OBJETIVO ESTRATÉGICO (Corporativo)

"Demostrar resiliencia cibernética mediante gestión inteligente de riesgos proporcional a probabilidad de explotación"

↓ DESCOMPONE EN

NIVEL 2: OBJETIVOS SECUNDARIOS (Operacionales)

OB-1: Reducir MTTR vulnerabilidades críticas
OB-2: Maximizar eficiencia operativa (evitar trabajo inútil)
OB-3: Demostrar cumplimiento regulatorio (NIS2/GDPR)
OB-4: Mejorar MTTD incidentes

↓ CADA OBJETIVO GENERA

NIVEL 3: PREGUNTAS DE NEGOCIO

Q1: ¿MTTR actual es <7 días para EPSS≥0.50?
Q2: ¿% de esfuerzo se dedica a CVEs nunca explotadas?
Q3: ¿Es documentada cada decisión priorización con EPSS?
Q4: ¿MTTD promedio <24 horas?

↓ CADA PREGUNTA RESPONDE CON

NIVEL 4: MÉTRICAS TÉCNICAS

M1: $MTTR_high_EPSS = \Sigma (Remediation - Detection) / Count(EPSS \geq 0.50)$
M2: $Waste_Effort = Horas_No_Explotadas / Horas_Totales \times 100\%$
M3: $Documented_Decisions = Decisiones_con_EPSS_doc / Total \times 100\%$
M4: $MTTD = \Sigma (Detection - Alert) / Count(Incidentes)$

↓ CADA MÉTRICA EVALUADA CON

NIVEL 5: CRITERIOS PRAGMATIC (9 dimensiones)

M1: Predictivo(6), Relevante(9), Accionable(9), Genuino(7),
Significativo(8), Preciso(6), Oportuno(8), Independiente(5),
Rentable(9) → PROMEDIO 7.3/10

Tabla de Trazabilidad Completa

Objetivo	Pregunta	Métrica	PRAGMATIC	Regulación	Clase
OB-1	Q1.1	MTTR_high_EPSS	7.3/10	NIS2 21(E)	B
OB-1	Q1.2	MTTR_low_EPSS	7.3/10	NIS2 21(E)	B
OB-2	Q2.1	Waste_Effort	7.2/10	GDPR 32	B
OB-3	Q3.1	Documented_Decisions	7.8/10	NIS2/GDPR	B+
OB-4	Q4.1	MTTD	7.5/10	GDPR 33	B

SECCIÓN 3: ANÁLISIS PRAGMATIC - PRACTICIDAD (2 páginas)

Matriz de Evaluación de 9 Criterios

CRITERIO 1: PREDICTIVO (¿Predice riesgos futuros?)

Score Promedio: 7.4/10

Interpretación: Las métricas tienen poder predictivo MODERADO-ALTO.

- ✓ MTTR histórico predice MTTR futuro si estable
- ✓ Efficiency EPSS predice precisión modelo futuro
- ✗ Phishing Click tasa no predice bien reinfecciones

Acción: Agregar trend metrics (mes-a-mes slope)

CRITERIO 2: RELEVANTE (¿Importa a stakeholders?)

Score Promedio: 9.0/10

Interpretación: Las métricas son ALTAMENTE RELEVANTES.

- ✓ CISO: KPIs estratégicos
- ✓ CFO: Impacto financiero cuantificable
- ✓ Auditor: Evidencia de compliance
- ✓ CEO: Indicadores de resiliencia

Acción: Ninguna; mantener.

CRITERIO 3: ACCIONABLE (¿Se puede actuar?)

Score Promedio: 8.3/10

Interpretación: Las métricas son MUY ACCIONABLES.

Si MTTR = 14 días (vs target 7):

- Acción 1: Aumentar personal remediación
- Acción 2: Automatizar patching
- Acción 3: Investigar bottlenecks

Acción: Documentar playbook de acciones por threshold.

CRITERIO 4: GENUINO (¿Mide lo que dice?)

Score Promedio: 8.0/10

Interpretación: Las métricas son GENERALMENTE GENUINAS.

- ✓ MTTR mide verdaderamente "tiempo remediación"
- ✗ PERO: ¿qué incluye "remediación"? ¿reintento si falla?
- ✗ PERO: Phishing Click tasa puede estar sesgada (empleados saben)

Acción: Crear "Diccionario de Métrica" con definiciones explícitas.

CRITERIO 5: SIGNIFICATIVO (¿Son cambios grandes?)

Score Promedio: 8.2/10

Interpretación: Los tamaños de efecto son OPERATIVAMENTE IMPORTANTES.

- ✓ MTTR de 30 → 7 días es cambio enorme (77% mejora)
- ✓ Efficiency de 40% → 65% es cambio significativo
- ⚠ Pero cobertura de 70% → 72% sería marginal

Acción: Definir "Cambio Mínimo Significativo" por métrica.

CRITERIO 6: PRECISO (¿Se mide sin ambigüedad?)

Score Promedio: 7.0/10

Interpretación: La precisión es MODERADA; requiere mejora.

-  "Fecha detección" → ¿cuándo scanner lo ve? ¿SIEM lo valida?
-  "Fecha remediación" → ¿re-escaneo? ¿cierre ticket?
-  Timestamps pueden tener drift entre sistemas

Acción: Implementar definiciones formales; automatizar medición.

CRITERIO 7: OPORTUNO (¿Se mide con frecuencia?)

Score Promedio: 8.4/10

Interpretación: La oportunidad es BUENA.

-  MTTR/MTTD reportable mensualmente
-  Cobertura EPSS en tiempo real (daily refresh)
-  Documentación auditada solo anualmente

Acción: Automatizar dashboards para weekly reporting.

CRITERIO 8: INDEPENDIENTE (¿Sin confounds?)

Score Promedio: 5.8/10

Interpretación: Las métricas son VULNERABLES a factores externos.

-  MTTR afectado por tamaño equipo (fuera control)
-  MTTD afectado por cambio SIEM tool
-  Phishing Click sesgo temporal (antes vs después capacitación)

Acción: Usar análisis causal (regression) para aislar efecto.

CRITERIO 9: RENTABLE (¿Costo vs valor?)

Score Promedio: 8.9/10

Interpretación: Las métricas son EXTREMADAMENTE RENTABLES.

-  MTTR/MTTD: recolección automática = €0 costo
-  ROI: €1 inversión → €3.30 valor (330% anual)
-  Payback: 3.8 meses

Acción: Implementar todas sin vacilar.

SECCIÓN 4: RECOMENDACIONES DE MEJORA (1 página)

Plan de Acción Priorizado

Prioridad	Acción	Plazo	Budget	Owner
MÁXIMA	Crear Diccionario de Términos (precisión +2 puntos)	Q1 2026	€5K	CISO
MÁXIMA	Mejorar MTTR a <7 días (vs actual 14 días)	Q2 2026	€50K	Lead Remediation
ALTA	Integración ML tuning SIEM (MTTD <12h)	Q2 2026	€50K	Lead SIEM
ALTA	Automatizar reportería semanal (vs mensual)	Q1 2026	€15K	Analytics
MEDIA	Análisis causal de métricas (independencia +1-2)	Q3 2026	€20K	Data Science
MEDIA	Playbook de acciones por threshold	Q1 2026	€5K	CISO

SECCIÓN 5: BUSINESS CASE (1 página)

ROI/ROSI Proyectado

INVERSIÓN (Año 1): €145K

- └ Diccionario + procesos: €5K
- └ Herramientas MTTR automation: €50K
- └ SIEM ML tuning: €50K
- └ Reportería dashboards: €15K
- └ Análisis causal consulting: €20K
- └ Contingencia (5%): €5K

BENEFICIO PROYECTADO:

- └ Reducción MTTR 14d → 7d:
 - └ Evita escalación a reguladores
 - └ Valor: €150K (menos exposición)
- └ Mejora MTTR 26h → 12h:
 - └ Prevención de lateral movement
 - └ Valor: €200K
- └ Mejor documentación compliance:
 - └ Evita multas NIS2
 - └ Valor: €300K
- └ Eficiencias operacionales:
 - └ Personal + herramientas
 - └ Valor: €100K

Total: €750K/año

$ROSI = (\text{€750K} - \text{€145K}) / \text{€145K} \times 100\% = 417\%$

Payback: 2.3 meses

3-año ROI: +280% acumulado

CONCLUSIÓN

Recomendación: APROBAR inversión de €145K para mejorar marco GQM+PRAGMATIC. Generará €750K en valor al año, con validación regulatoria completa (NIS2, GDPR, ENS).

*Reporte desarrollado por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad
Enero 2026*